



腾讯安全



云鼎实验室

锋刃无影 御见未来

腾讯安全沙龙第4期（长沙站）



关于我
About me

刘诚

腾讯云鼎实验室安全工程师
云鼎攻防团队红队成员
专注于红蓝攻防中各类红队技战法研究与武器化建设。



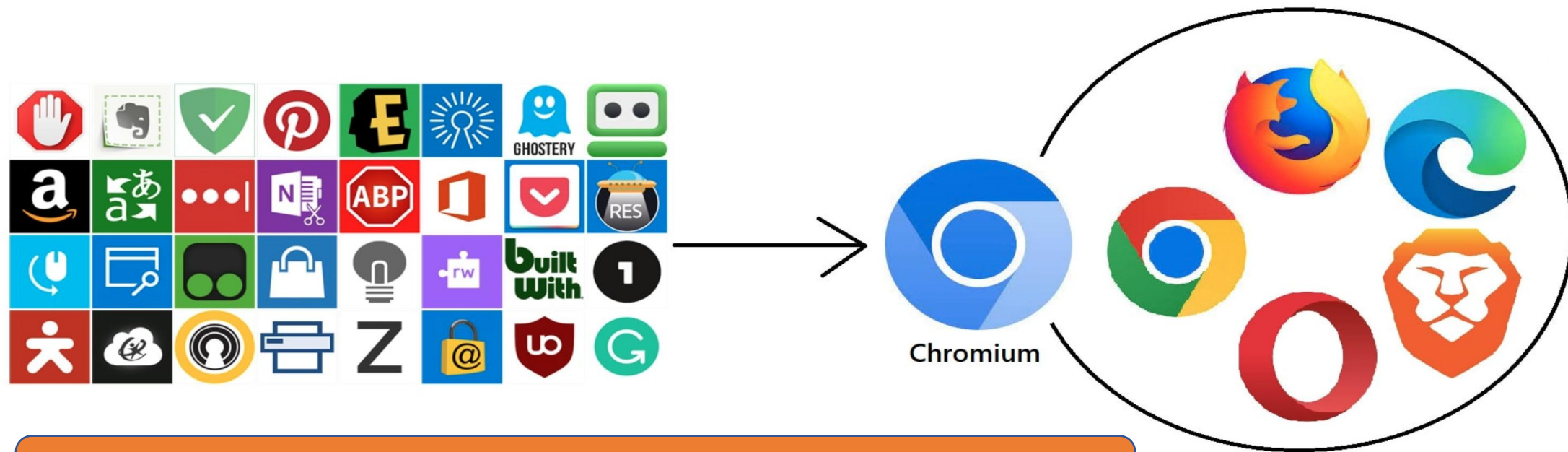
后渗透新维度：利用Chrome插件后门 实现持久化与凭据窃听



0x01 Chrome插件安全风险



Chrome插件市场高度成熟



市场占有率高，自定义程度高，也对应出在攻防中的巨大攻击面潜力。



Chrome插件安全影响巨大

根据斯坦福大学的一项研究表示Google的能力有限，无法控制庞大的扩展帝国。

3.6亿用户至少安装了一个存在安全风险的插件

良性扩展在插件商店平均驻留时间为**1152**天

2.8亿用户下载了含有恶意软件的扩展程序

易受攻击扩展的平均驻留时间为**1248**天，超过3年

6300万用户安装了违反 CWS 政策的扩展程序

含有恶意软件的扩展的平均驻留**380**天，超过1年

300万用户安装了存在漏洞的插件

名为“TeleApp”的恶意软件扩展在商店中停留了惊人的**8.5**年

Chrome插件后门的隐蔽性

以Chrome插件作为后门，能够绕开常规检测面，另辟蹊径。

01

进程可信

Chrome插件的行为，都依托于Chrome进程。包括对凭据的提取、数据的外发，都由Chrome进程执行。

02

低感知

插件静默安装，默认安装不展示在用户浏览器页面。且插件后台脚本，无界面、无弹窗，用户难以感知其运行。

03

动态加载

Chrome插件可以动态的从C2中加载需要执行的JS代码段完成攻击，保证攻击载荷不在插件中留存。

04

代码混淆

插件后门虽为JS代码，用户可直接查看，但是拓展插件的JS可以制作针对性的JS混淆对抗逆向分析

Chrome插件的运行原理

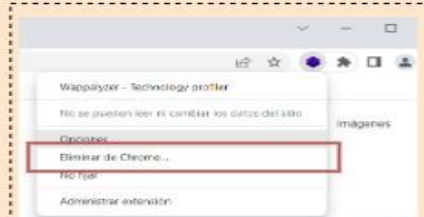
Chrome

Extension

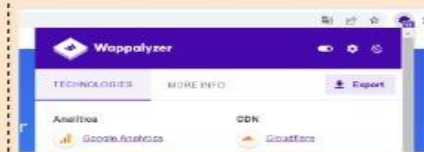
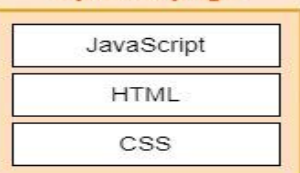
User Interface elements



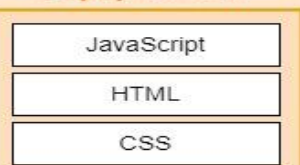
Toolbar icon



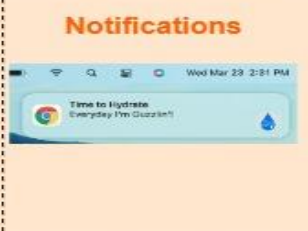
Options page



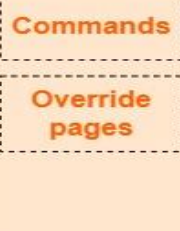
Popup window



Context menu

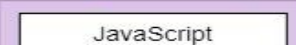


Notifications



Background

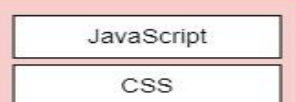
Background scripts



Storage

Content

Content scripts



Chrome data

Cookies

History

Downloads

Bookmark

...

Web page



Chrome插件的核心功能与权限列表



权限	危害	风险等级
Cookies	可以进行Cookie窃取与监听	严重
Debugger	检测网络交互，调试 JavaScript，改变页面等	严重
WebRequest	可以嗅探网络请求中敏感数据	严重
<all_urls>	允许访问所有目标，能够读取和修改所有网站上的所有数据。	严重
History	获得历史的完全访问权限。	高危
DesktopCapture	截取您的桌面屏幕截图。	高危
Tabs	赋予与浏览器标签交互的能力	高危
WebNavigation	可以监听访问的网站的信息。	高危
Clipboard	读取你复制的剪切板数据	高危
Proxy	获取并设置浏览器的代理配置。	高危

Chrome插件杀伤链



初始安装

初始安装方式

- 静默安装
- 插件投毒
- 浏览器漏洞
- 参数安装



持久化

- 远程代码加载
- 合法的进程链
- 合法的网络请求
- EDR检测规避



权限获取

- `https: // */ *`
- 网络请求控制
- cookies访问权限
- 桌面捕捉权限
- 代理设置
- 历史记录访问
- 剪贴板访问
- 键盘记录监控
- ...



恶意行为

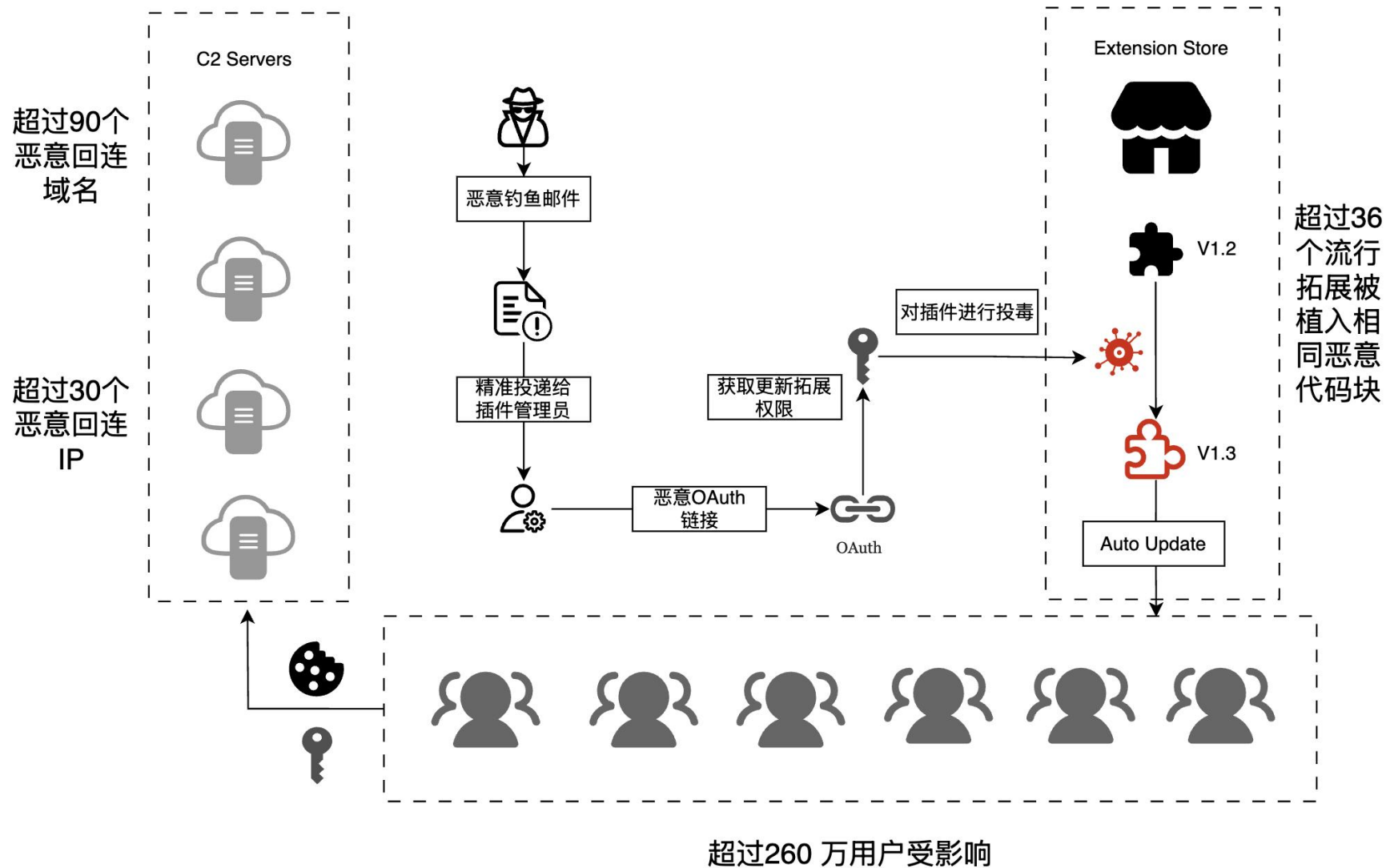
- 广告欺诈
- 页面劫持
- 数据泄露
- 凭证盗窃
- 恶意代码
- 勒索软件



变现

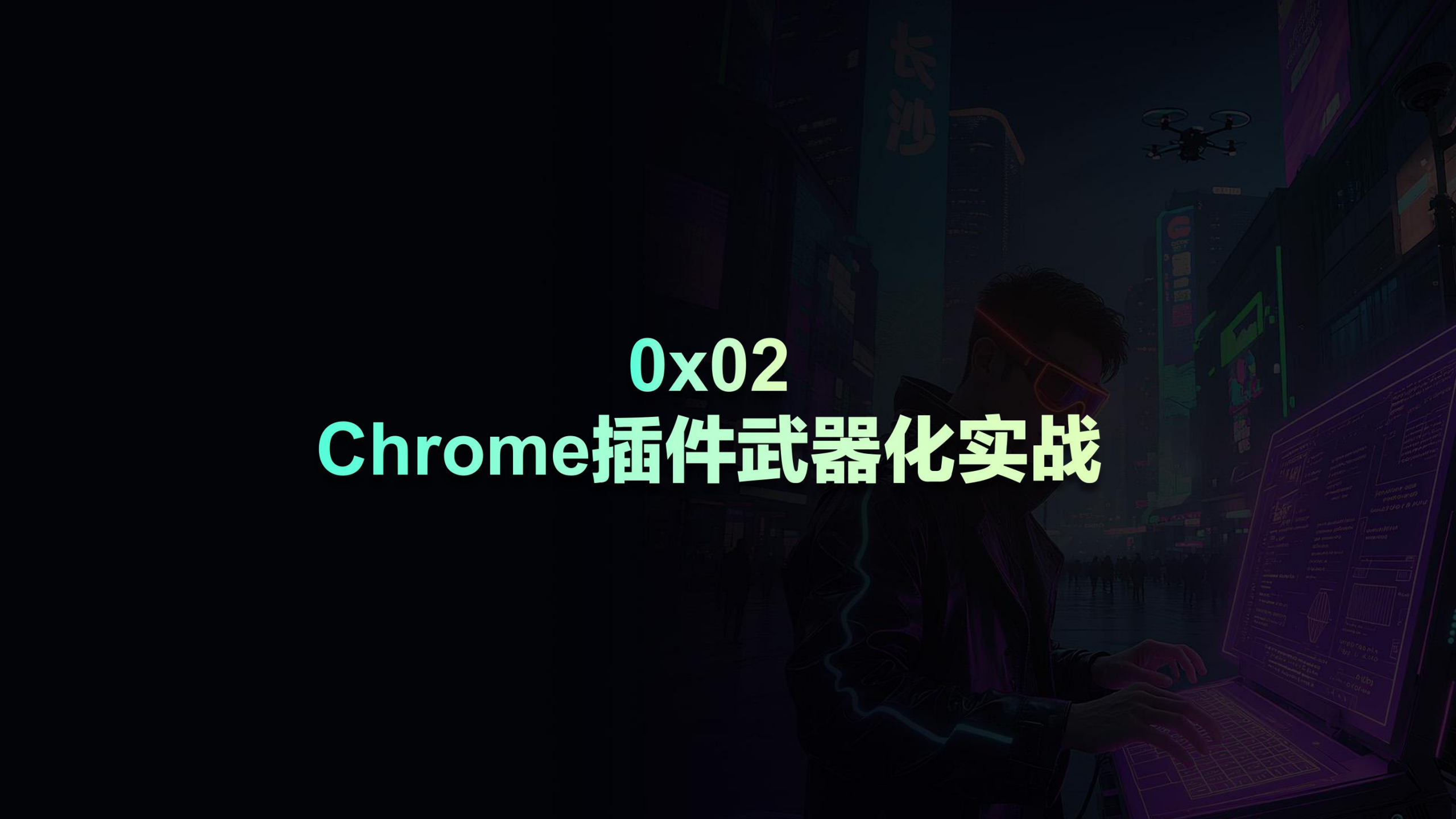
- 个人身份信息
- 财务记录
- 登录凭证
- 公司数据
- 浏览历史记录
- 行为数据

Chrome插件在APT中的利用 —— Cyberhaven



事件描述

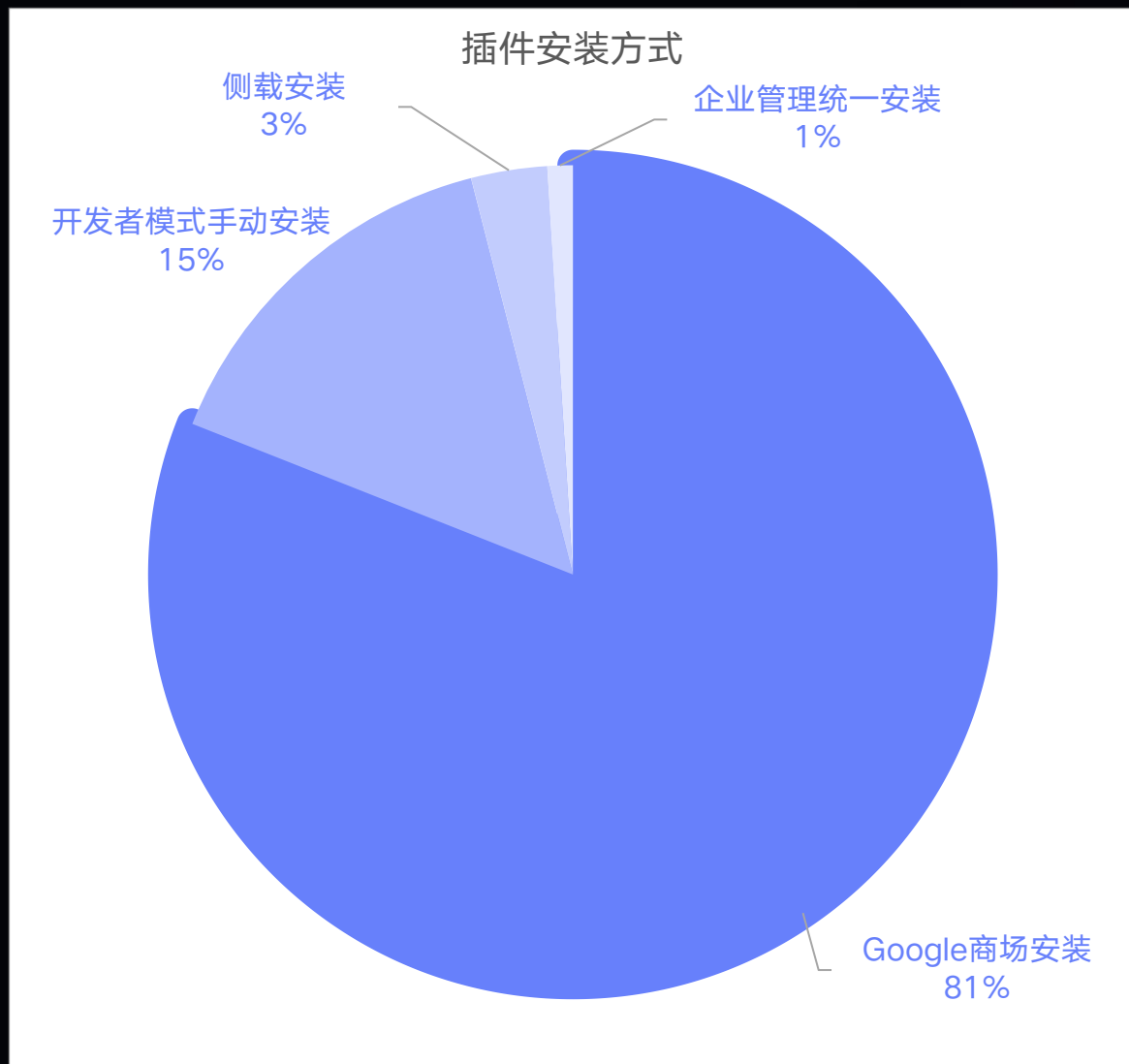
Cyberhaven 是一家网络安全公司，其 Chrome 浏览器扩展遭遇重大漏洞，攻击者利用该漏洞向用户浏览器注入恶意代码。这些代码能够窃取敏感数据，包括密码和 cookies，导致约 40 万用户的安全受到威胁。在此次漏洞事件后，一个针对 Chrome Web Store 260 万用户的威胁活动被曝光。

A cyberpunk-themed illustration of a person wearing a black jacket and glowing orange-rimmed glasses, sitting at a desk and typing on a laptop. The laptop screen displays a complex interface with various charts and data. The background is a dark, neon-lit city street at night, with tall buildings, glowing signs, and a drone flying in the sky. The overall color palette is dominated by dark blues, purples, and oranges.

0x02

Chrome插件武器化实战

Chrome插件的初始化安装



插件安装方式

- ① 在Chrome插件的多种安装方式中，最通用的是用户从谷歌商城下载安装；
- ② 其次是插件无法上架谷歌商城，用户开启开发者模式后手动加载安装；
- ③ 其中有一种小众的安装方式——侧载安装，这里官方的加载方式是在启动浏览器时，加上参数load-extension来指定插件。但是这种方式存在局限性，关闭后就无法再次使用。

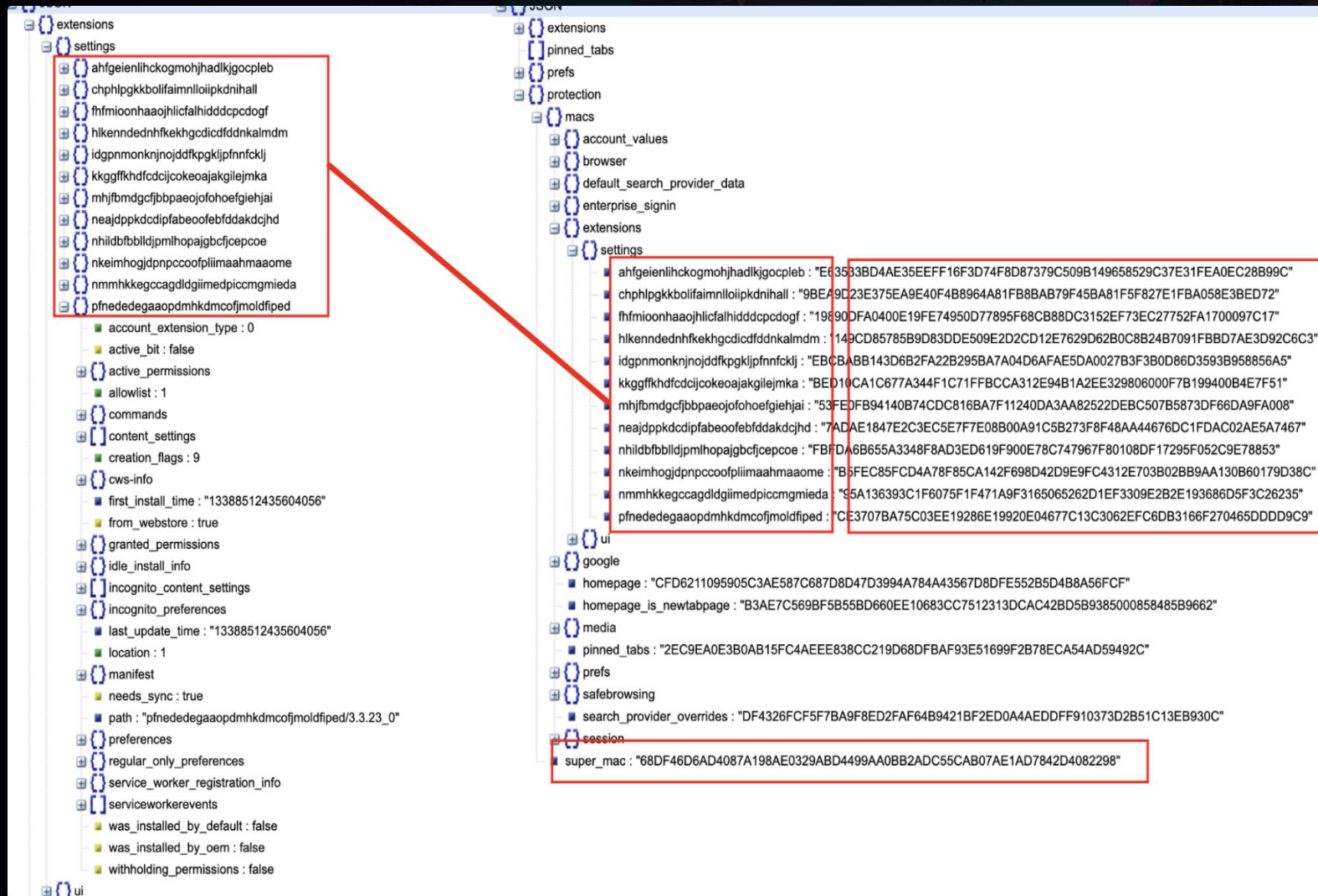
Chrome插件的安全加固

2012年以前

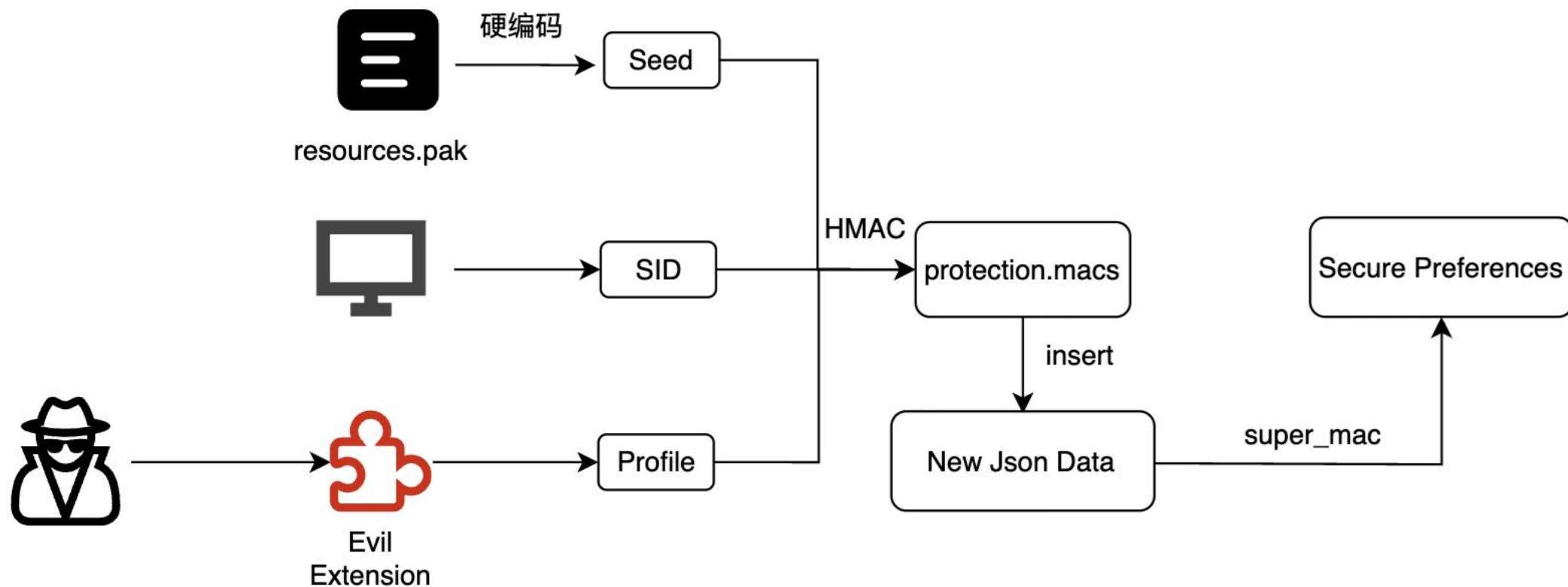
2012 年发布的 25.0.1212.0 版本前，攻击者可以直接在Secure Preferences文件中直接添加需要安装的插件基本选项，Chrome不校验插件来源。

2012年以后

从 2012 年发布的 25.0.1212.0 版本开始，Google 决定不允许除浏览器以外的其他来源通过在 Secure Preferences 文件中直接添加选项来修改用户的配置。当用户打开浏览器时，浏览器会重新计算所有 HMAC 并检查它们是否由浏览器创建，最后再计算一个总的super_mac校验配置的完整性。



Chrome插件的静默安装



获取目标信息

定位配置文件

获取目标信息

插入恶意扩展

计算扩展独立HMAC

更新 protection.macs

更新 super_mac

拓展成功安装

Chrome插件的静默安装

获取目标信息

提取当前计算机SID值，可以通过执行一下命令提取uid：
unix下：system_profiler SPHardwareDataType
windows下：wmic useraccount

获取目标信息

HMAC算法的Seed为硬编码，可直接使用：

b'\xe7H\xf36\xd8^\xa5\xf9\xdc\xdf%\xd8\xf3G\xa6[L\xdfv\x00\xf0-\xf6rJ*\xf1\xa!-
&\xb7\x88\xa2P\x86\x91\x0c\xf3\xa9\x03\x13ihq\xf3\xdc\x05\x8270\xc9\x1d\xf8\xba\O\xd9\xc8\x84\xb5\x05
\xa8'

计算扩展HMAC

```
if ((type(value_as_string) == type({})) or (type(value_as_string) == type(OrderedDict()))):  
    removeEmpty(value_as_string)  
message = sid + path + json.dumps(value_as_string, separators=(',', ':'), ensure_ascii=False).replace('<', '\\u003C').replace(  
    '\\u2122', '™')  
hash_obj = hmac.new(seed, message.encode("utf-8"), hashlib.sha256)  
  
return hash_obj.hexdigest().upper()
```

代码示例可以参考GitHub项目：<https://github.com/Pica4x6/SecurePreferencesFile>

Chrome插件后门武器化功能一览

平台

窃密模块

攻击模块

凭证提取

Cookie监听

页面监听

History提取

网络监听

键盘监听

Bookmark提取

屏幕截取

地址获取

恶意脚本植入

凭据删除

DNS劫持 (nightly)

网络代理

请求劫持

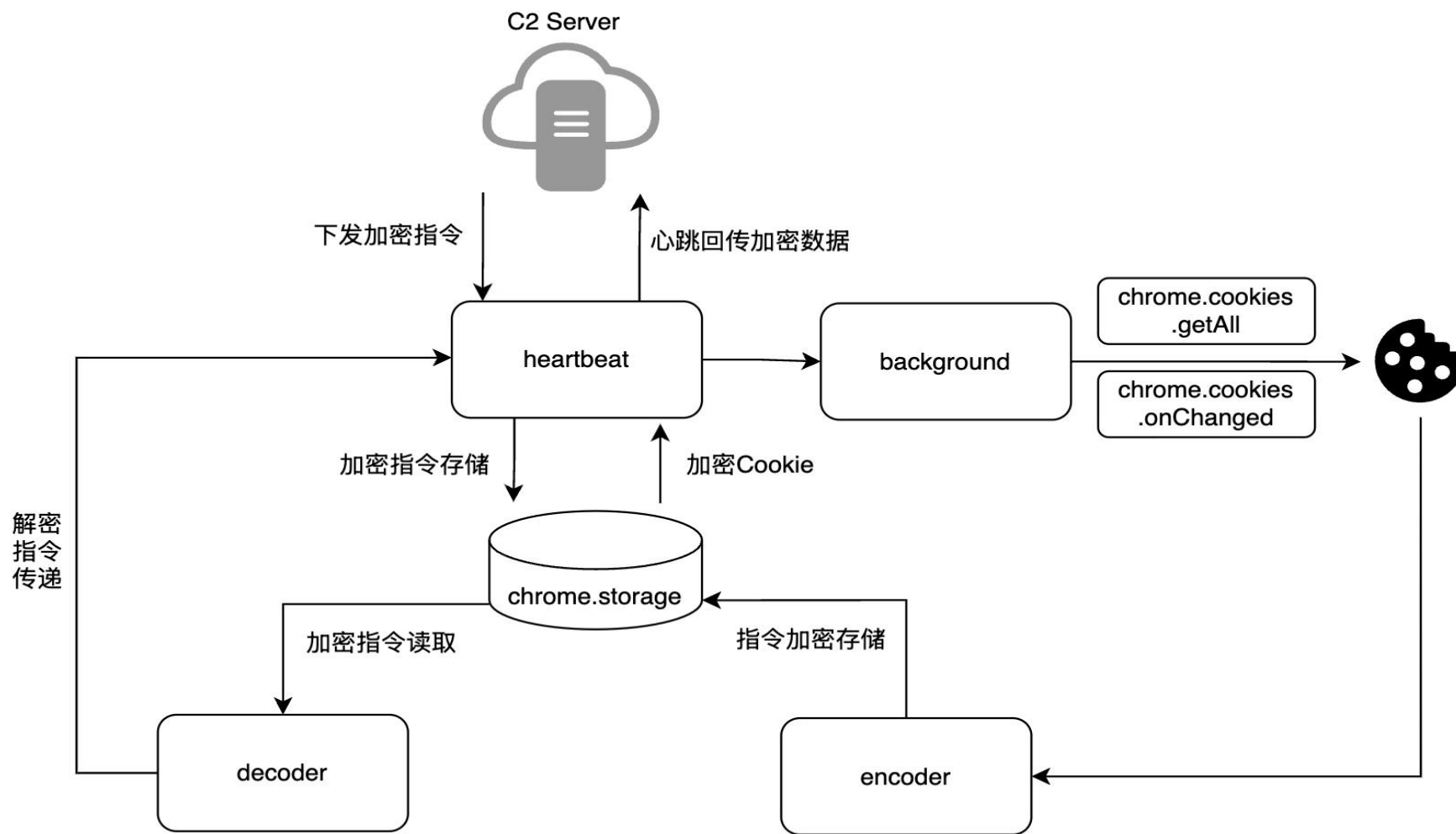
本地服务攻击

网络扫描

DOM修改

诱导性通知

Chrome插件后门武器化——Cookie窃听



Chrome API调用

`chrome.cookies`

`chrome.storage`

`chrome.runtime`

Fetch

Chrome插件后门武器化——Cookie窃听

📄

📄

📄

-7f5117415db8a697

在线

历史记录

书签管理

Cookie监控

页面监控

网络监控

攻击模块

搜索域名

序号	域名	名称	值	过期时间	操作类型
1	.bing.com	SRCHD	AF=NOFORM	2026/04/30 14:23:54	新增
2	.bing.com	SRCHUID	V=2&GUID=60BED94945AE...	2026/04/30 14:23:54	新增
3	.bing.com	MUIDB	1A4A640BE5F664AB033C7...	2026/04/20 14:23:54	新增
4	.bing.com	_UR	QS=0&TQS=0&Pn=0	2026/05/07 17:27:11	新增

序号1详情

×

域名

.bing.com

名称

SRCHD

值

AF=NOFORM

路径

/

过期时间

2026/04/30 14:23:54

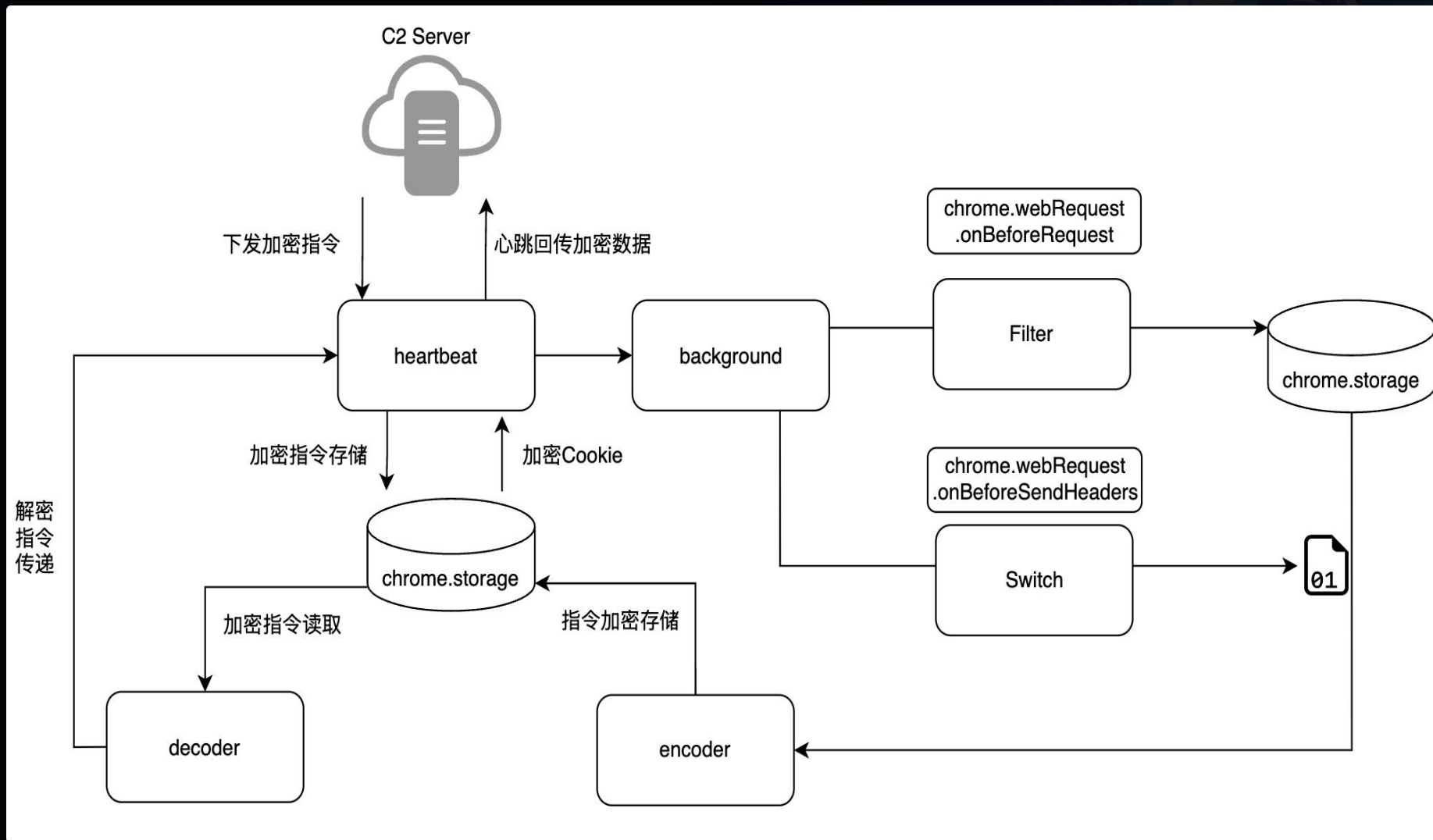
创建时间

1970/01/21 14:03:31

操作类型

新增

Chrome插件后门武器化——请求窃听



Chrome API调用

`chrome.webRequest`

`chrome.storage`

`chrome.runtime`

Fetch

Chrome插件后门武器化——请求窃听

🏠 主页

📁 书签

🔍 搜索

📄 历史记录

📖 书签管理

🍪 Cookie监控

📄 页面监控

🌐 网络监控

🔥 攻击模块

🔍 搜索网址

🔍

🔍 开始监控

序号	URL	方法	请求时间	操作
1	https://otheve.beacon.qq.com/analytics/v2_upload?appkey=	POST	18:43:34	🔍 详情
2	https://otheve.beacon.qq.com/analytics/v2_upload?appkey=	POST	18:43:33	🔍 详情

序号1详情

关闭全部

URL

https://otheve.beacon.qq.com/analytics/v2_upload?appkey=

🔍 复制

Headers

Accept

application/json, text/plain, /*

🔍 复制

Content-Type

application/json;charset=utf-8

Sec-Fetch-Dest

empty

Sec-Fetch-Mode

cors

Sec-Fetch-Site

same-site

User-Agent

Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/137.0.0.0 Safari/537.36

sec-ch-ua

"Google Chrome";v="137", "Chromium";v="137", "Not(A)Brand";v="24"

sec-ch-ua-mobile

?0

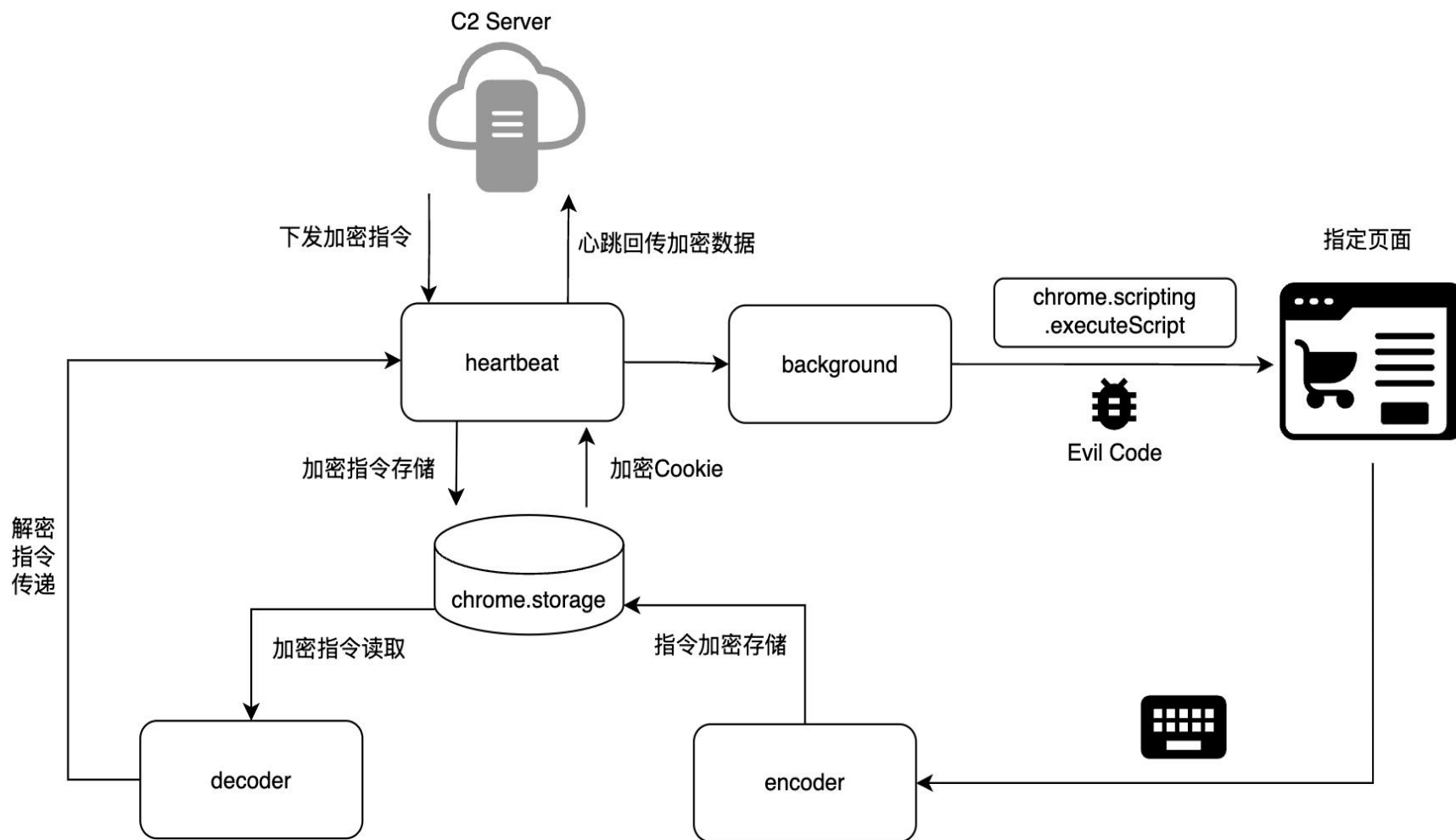
sec-ch-ua-platform

"macOS"

请求体

```
{  "appVersion": "",  "sdkId": "js",  "sdkVersion": "4.5.14-web",  "mainAppKey": "",  "platformId": 3,  "common": {    "UA": "Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/137.0.0.0 Safari/537.36"  }}
```

Chrome插件后门武器化——键盘窃听



Chrome API调用

`chrome.scripting`

`chrome.storage`

`chrome.runtime`

Fetch

Chrome插件后门武器化——键盘窃听

🖥️

🖥️

🖥️

-7f5117415db8a697

在线

历史记录

书签管理

Cookie监控

页面监控

网络监控

攻击模块

搜索标签页

🔍

🕒 开始监控

序号	tab_id	标题	网址	操作
1	16065029	腾讯网	https://www.qq.com/	键盘记录 详情
2	16065041	腾讯网-要闻	https://news.qq.com/	键盘记录 详情

共 2 条 < 1 >

● keyboard-16065029 ✕

● keyboard-16065041 ✕

键盘记录

🕒 开始监控

a

d

m

i

n

1

2

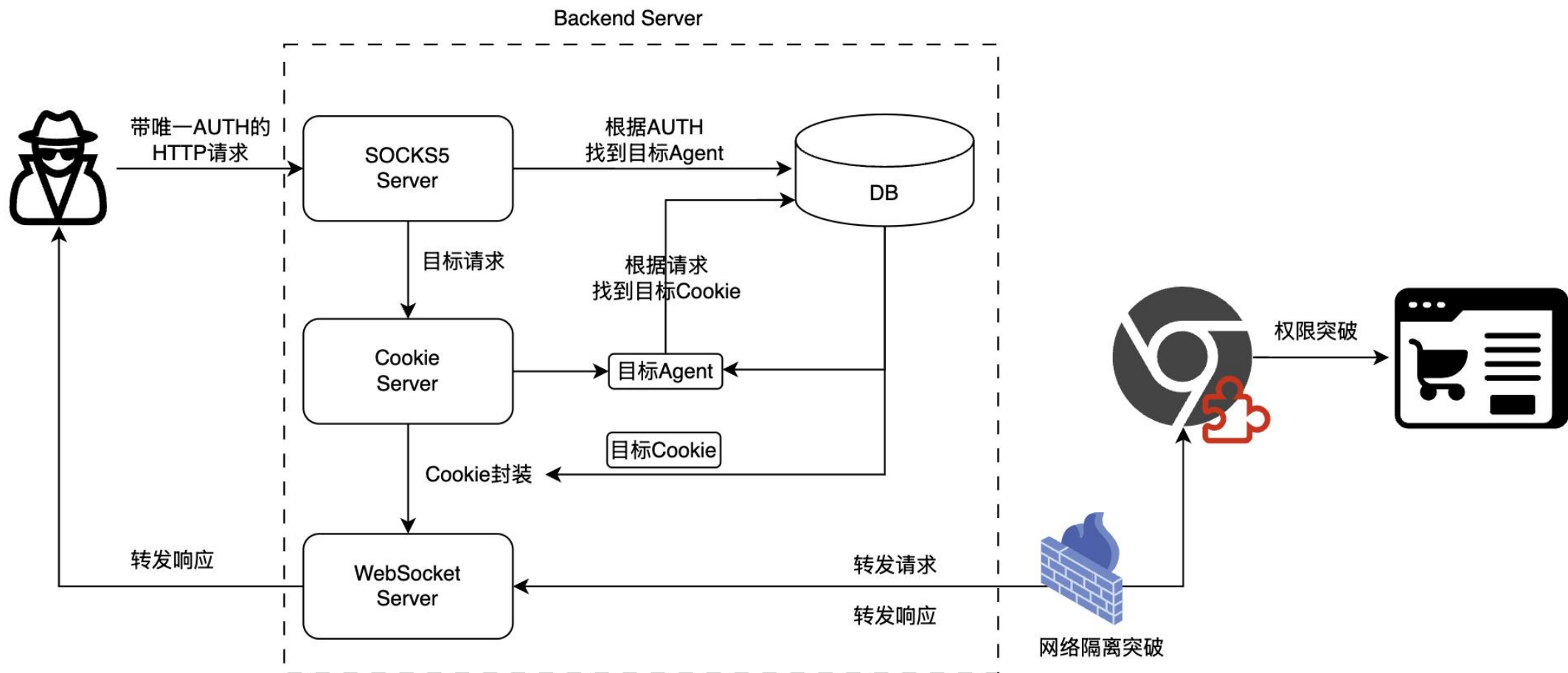
3

4

5

6

Chrome插件后门在横向移动中的利用——Proxy



谢谢

